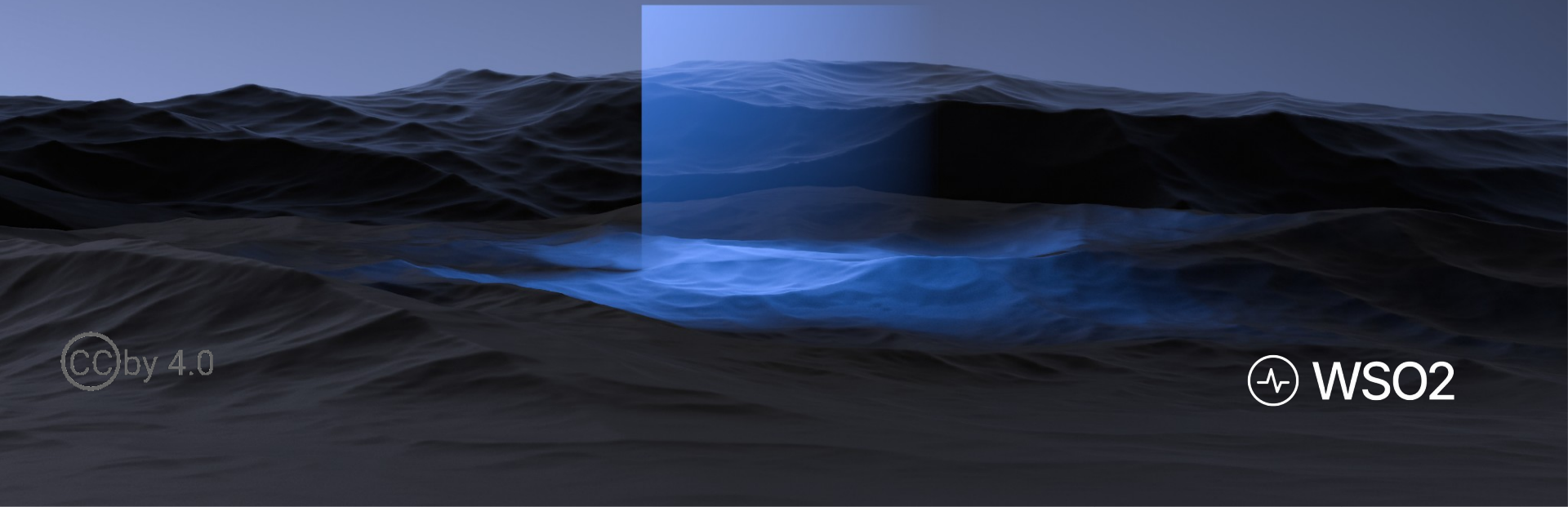
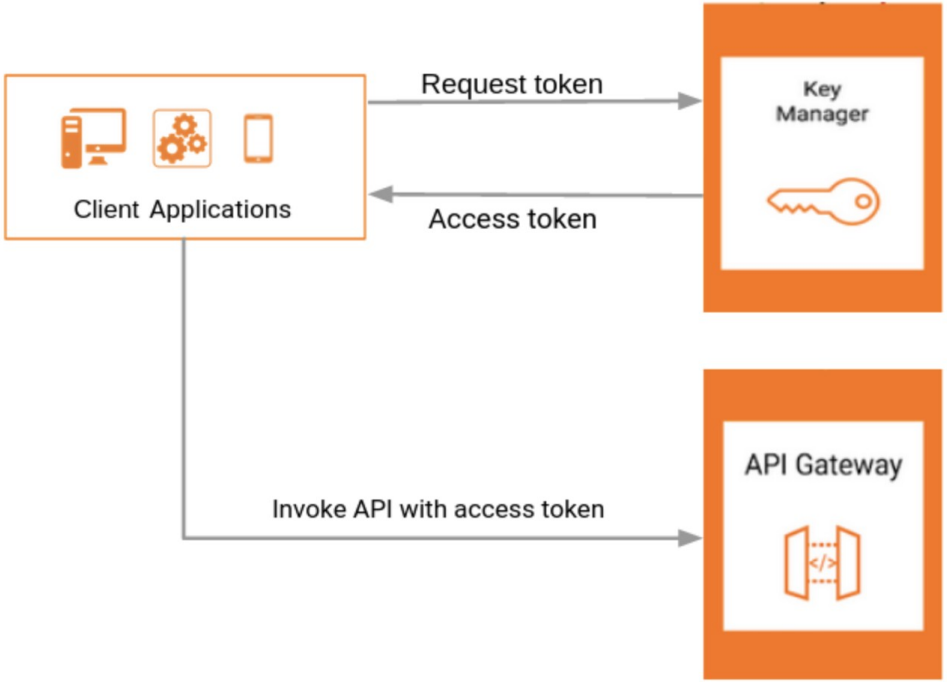
Key Management



CC by 4.0

WSO2

Key Manager Overview



Key Manager

Key Manager

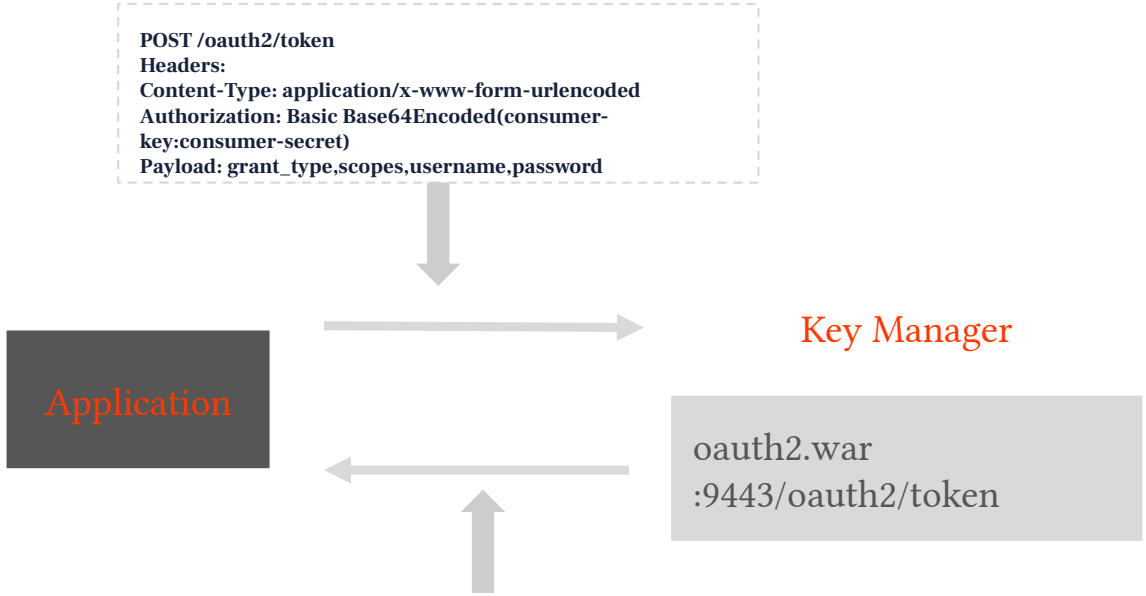
- The Key Manager handles all clients, security and access token-related operations.
- A subscriber can generate a consumer key and a consumer secret once an application is created. In the above scenario, the API Developer Portal will direct the call to the Key Manager.
- When a subscriber generates an access token to the application using the API Developer Portal, the Developer Portal makes a call to the Key Manager to create an OAuth App and obtain an access token.
- In a typical production environment, you can configure one of the following setups:

    Configure a WSO2 API Manager instance as the Key Manager.

    Configure an instance of WSO2 Identity Server as the Key Manager.

    Configure a third-party authorization server such as Okta, KeyCloak, Auth0, PingFederate, ForgeRock for key validations.

Token Generation Flow



Configuring a Third Party Key Manager













Configure WSO2 Identity Server as Key Manager

Configure Okta as a Third Party Key Manager

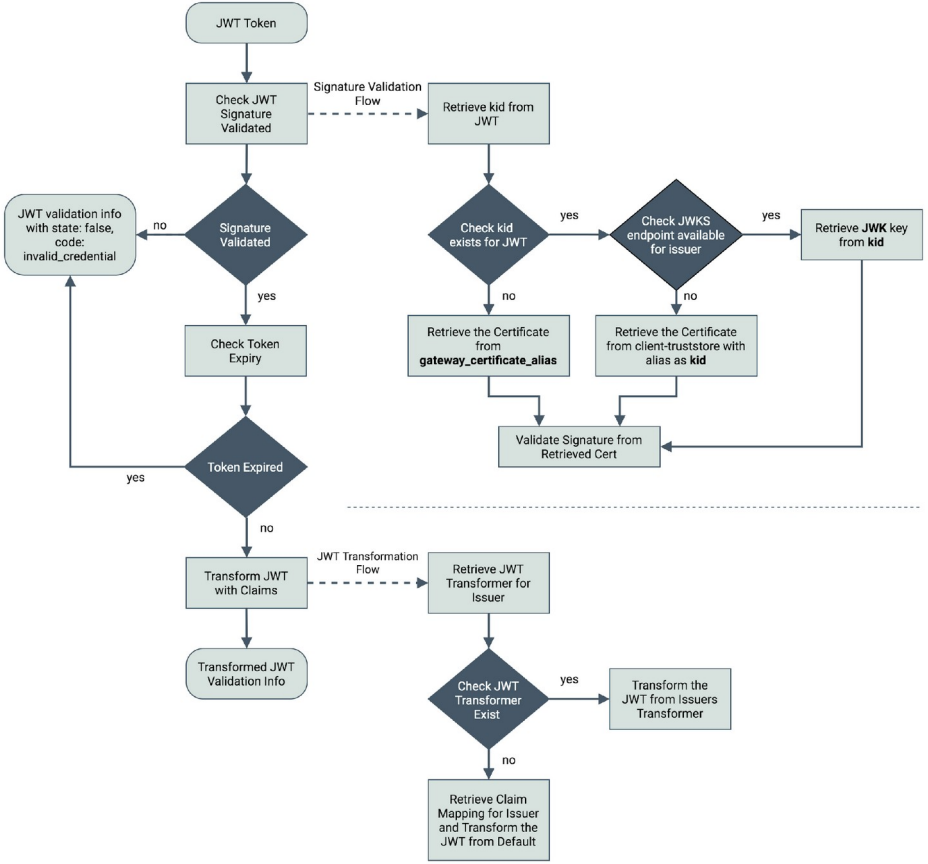
Configure Keycloak as a Third Party Key Manager

Configure Auth0 as a Third Party Key Manager

Configure PingFederate as a Third Party Key Manager

Configure ForgeRock as a Third Party Key Manager

Validating the Token at Gateway



Scope Validation

- OAuth scopes allow you to have fine-grained access control to API resources based on the user roles.
- API Manager uses scopes as a way of defining permissions for a resource.
- Validating the role of a requester does not make much sense in some scenarios. For instance, when the scope is used as a means of generating an access token and not for securing a resource (e.g. OpenID scope). In such situations, scope validation can be extended to skip role validation for certain scopes.

Extending Scope Validation

- When scopes that cannot be associated to roles are requested, the token should be issued without validating the scope.
- In WSO2 API Manager, you do this by allowing the scope through a configuration.
- Scopes that match the pattern are not validated by role and are available to anyone requesting it.

```
[apim.oauth_config]
allowed_scopes = ["^device_.*", "openid", "some_random_scope"]
```

Extending Scope Validation

Extending Key Manager Interface

- **Key Manager** interface acts as the bridge between the OAuth Provider and WSO2 API Manager.
- In order to plug an external OAuth2 Authorization server as the Key Manager for API-M you should implement a third-party Key Manager Connector by extending the Key Manager Interface.

Configure a Custom Key Manager

Let’s try it out!

WSO2 Identity Server as the Key Manager

WSO2